



SAÉ - Conformité réglementaire pour traiter/analyser des données

Le RGPD c'est quoi ?	2
1/ Mettre en place un registre des activités	2
2/ Préciser les parties prenantes (représentant, sous-traitants, co-responsables, etc.) qui interviennent dans le traitement des données. C'est à dire définir :	3
3/ Définir les catégories de données traitées :	4
4/ Déterminer ce à quoi servent ces données (ce qui en est fait), qui accède aux données et à qui elles sont communiquées.....	4
5/ Définir le temps de conservation des données	5
6/ Montrer comment les données sont sécurisées	5
7/ Suppression de certaines données collectées (notamment les données dites sensibles)	6
8/ Recommandation.....	7
a) Mesures organisationnelles	7
b. Droits des salariés.....	7
c. Documentation et traçabilité.....	8
d. Sensibilisation et amélioration continue.....	8
La conformité RGPD n'est pas un projet ponctuel, mais une démarche continue :	8
e. Plan d'action de mise en conformité.....	8
Conclusion	9

Le RGPD c'est quoi ?

Le Règlement Général sur la Protection des Données (RGPD), en vigueur depuis le 25 mai 2018, impose des obligations strictes aux entreprises traitant des données personnelles, y compris les données des employés. Pour cette entreprise industrielle d'une centaine de salariés, qui n'a encore rien mis en place, l'urgence d'agir est réelle afin d'éviter des amendes pouvant atteindre 4 % du chiffre d'affaires annuel mondial, des plaintes d'employés ou des fuites de données. Le service RH manipule des données sensibles (santé, appartenance syndicale), augmentant ainsi les risques de non-conformité.

Déterminons de façon très précise ce que doit faire l'entreprise pour être en conformité par rapport au Règlement Général sur la Protection des Données

1/ Mettre en place un registre des activités

Cette mise en place est recommandée pour une entreprise de moins de 250 salariés et dans le cas échéant cela est obligatoire. Il faudra choisir un membre RH formé ou un externe compétent en droit des données, indépendant et rapportant à la direction. Il sera alors enregistré sur le site de la CNIL via un formulaire en ligne. Il conseillera, contrôlera et coopérera avec la CNIL.

Le registre devra refléter la réalité des traitements de données personnelles et devra permettre d'identifier précisément les parties prenantes qui interviennent dans le traitement des données, les catégories de données traitées et tous les autres critères prouvant le respect des principes du RGPD.

2/ Préciser les parties prenantes (représentant, sous-traitants, co-responsables, etc.) qui interviennent dans le traitement des données. C'est à dire définir :

- Le cas échéant, le nom et les coordonnées du responsable conjoint du traitement mis en œuvre
- Les finalités du traitement, l'objectif en vue duquel vous avez collecté ces données
- Le responsable du traitement : c'est l'entreprise elle-même (ex. : la société industrielle) qui détermine les finalités et les moyens du traitement des données personnelles.
- Le représentant du responsable du traitement : dans le cas d'un groupe ou d'une société étrangère, il s'agit de la personne ou de la filiale désignée pour représenter le responsable du traitement au sein de l'Union européenne.
- Le délégué à la protection des données (DPO) : il conseille, contrôle et veille au respect du RGPD au sein de l'entreprise.
- Les sous-traitants : ce sont les prestataires externes qui traitent des données pour le compte de l'entreprise (ex. : cabinet comptable, logiciel de paie, service de maintenance informatique, hébergeur cloud).
- Les co-responsables du traitement : lorsque deux entités déterminent ensemble les finalités et les moyens du traitement (ex. : un partenaire industriel ou un cabinet de recrutement travaillant conjointement avec l'entreprise).
- Les destinataires internes : services ou personnes au sein de l'entreprise qui ont accès aux données (ex. : service RH, comptabilité, direction).
- Les destinataires externes : organismes ou institutions auxquels les données peuvent être transmises (ex. : URSSAF, mutuelle, organismes de retraite, médecine du travail).

3/ Définir les catégories de données traitées :

Cette étape a déjà été traitée car le tableau soumis montre que le service RH a défini les différentes catégories de données traitées

- **Identification de l'employé** : cette catégorie a été divisée en quatre classes (données relatives à l'identité, données relatives à la situation professionnelle, Données relatives au titre valant autorisation de travail, Coordonnées des personnes à prévenir en cas d'urgence)
- **Suivi de la carrière et de la formation de l'employé** : cette catégorie est divisée en trois classes (gestion de la carrière de l'employé, évaluation professionnelle de l'employé, Suivi administratif des visites médicales des employés)

4/ Déterminer ce à quoi servent ces données (ce qui en est fait), qui accède aux données et à qui elles sont communiquées

Il faudra :

- Préciser clairement les informations relatives aux catégories de destinataires auxquels les données à caractère personnel ont été ou seront communiquées, y compris les sous-traitants auxquels vous recourez
- Expliciter tout transfert de données à caractère personnel vers un pays tiers ou à une organisation internationale et, dans certains cas très particuliers, les garanties prévues pour ces transferts

5/ Définir le temps de conservation des données

(Les délais prévus pour l'effacement des différentes catégories de données, c'est-à-dire la durée de conservation, ou à défaut les critères permettant de la déterminer)

Les données personnelles traitées par le service des Ressources Humaines doivent être conservées uniquement pendant la durée nécessaire à leur utilisation, conformément. Les données administratives et professionnelles des salariés sont gardées pendant toute la durée du contrat de travail, puis archivées pendant cinq ans après leur départ. Les données de paie et de cotisations sociales sont conservées cinq ans selon les obligations légales. Les informations sur la carrière, la formation et les évaluations sont également conservées pendant le contrat et jusqu'à cinq ans après sa fin. Les données sensibles, comme celles relatives à la santé, ne doivent être gardées que le temps strictement nécessaire, au maximum un an après le départ du salarié. Les sanctions disciplinaires sont effacées au bout de trois ans, et les candidatures non retenues sont conservées deux ans après le dernier contact. Au-delà de ces délais, les données doivent être supprimées, anonymisées ou archivées de façon sécurisée.

Les données personnelles doivent être conservées uniquement le temps nécessaire à leur finalité.

Type de données	Durée de conservation
Données du dossier salarié	Durée du contrat + 5 ans
Bulletins de paie / cotisations	5 ans (obligation légale)
Évaluations et formations	Durée du contrat + 5 ans
Données santé (aptitude, RQTH)	1 an maximum après départ
Sanctions disciplinaires	3 ans maximum
Candidatures non retenues	2 ans après le dernier contact

6/ Montrer comment les données sont sécurisées

(Dans la mesure du possible, une description générale des mesures de sécurité techniques et organisationnelles mises en œuvre)

Afin de protéger les données personnelles traitées par le service des Ressources Humaines, l'entreprise doit appliquer des mesures de sécurité techniques et organisationnelles. Sur le plan technique, l'accès aux données doit être protégé par des identifiants personnels, des mots de passe sécurisés et, si possible, une authentification à double facteur. Les ordinateurs et serveurs doivent être équipés d'un antivirus, d'un pare-feu et de mises à jour automatiques. Les données sensibles (comme celles relatives à la santé ou à l'appartenance syndicale) doivent être chiffrées et sauvegardées régulièrement sur des supports sécurisés. L'accès aux informations doit être limité aux seules personnes autorisées.

Sur le plan organisationnel, le Délégué à la Protection des Données (DPO) servira à former le personnel à la confidentialité et mettre en place des procédures internes pour la gestion des accès, la déclaration des incidents et la confidentialité des sous-traitants. Un registre des incidents et des audits réguliers doit être tenus pour vérifier le respect des règles (comme annoncé ci-dessus). Ces mesures visent à garantir la confidentialité, l'intégrité et la sécurité des données personnelles des employés.

7/ Suppression de certaines données collectées (notamment les données dites sensibles)

Le principe fondamental du RGPD est que seules les données strictement nécessaires doivent être collectées et traitées. Une part importante des informations actuellement conservées par le service RH est superflue, voire illégale.

Nous devons donc supprimer les données suivantes car elles ne sont pas pertinentes pour la gestion du personnel :

- **Données relatives à la vie privée et familiale**
 - ❖ La profession des parents de l'employé.
 - ❖ La nature des études suivies par les enfants.
 - ❖ La situation familiale et matrimoniale détaillée. L'enregistrement de ces informations ne peut se justifier que pour l'attribution d'avantages sociaux spécifiques.

- **Données "sensibles" dont le traitement est interdit :**

- ❖ L'appartenance syndicale du salarié. Il est en principe interdit de traiter cette information.
- ❖ Le nombre de jours de grève suivis. Cette donnée peut indirectement révéler une appartenance syndicale et n'est pas pertinente pour l'évaluation professionnelle.
- ❖ L'indication des pathologies des salariés. Il est formellement interdit de collecter des données relatives à la santé des personnes, sauf exceptions très encadrées. Le service RH ne doit conserver que l'avis du médecin du travail (apte, inapte, adaptation de poste), mais jamais le diagnostic médical.

Sinon dans le cas de vouloir garder certaines de ces données, définir de manière très explicite l'objectif attendu sur ces données.

8/ Recommandation

a) Mesures organisationnelles

- Gestion des droits d'accès : chaque collaborateur n'accède qu'aux données nécessaires à sa fonction.
- Sensibilisation du personnel RH à la confidentialité.
- Signature d'engagements de confidentialité.
- Audit régulier et registre des incidents de sécurité.
- Procédure interne pour la déclaration des violations de données :

Tout incident (perte, vol, envoi erroné) doit être signalé immédiatement au DPO, qui analysera la gravité et notifiera la CNIL sous 72h si nécessaire.

b. Droits des salariés

Chaque salarié dispose des droits suivants :

- **Droit d'accès** : obtenir une copie de ses données.
- **Droit de rectification** : corriger des informations erronées.

- **Droit à l'effacement** : suppression des données non nécessaires.
- **Droit à la limitation ou opposition** : refuser certains traitements.
- **Droit à la portabilité** : recevoir ses données dans un format lisible.

L'entreprise doit créer une procédure claire (adresse e-mail dédiée, formulaire interne) pour traiter ces demandes sous un mois maximum.

c. Documentation et traçabilité

Pour démontrer sa conformité, l'entreprise doit conserver :

- Le registre des traitements ;
- Les contrats avec les sous-traitants ;
- Les preuves de consentement (pour les candidats) ;
- La politique de sécurité interne ;
- Le registre des incidents et violations de données.

Ces éléments serviront de preuve de conformité en cas de contrôle de la CNIL.

d. Sensibilisation et amélioration continue

La conformité RGPD n'est pas un projet ponctuel, mais une démarche continue :

- Formation annuelle du personnel RH et des managers.
- Vérification régulière du respect des bonnes pratiques.
- Audit interne RGPD chaque année.
- Mise à jour du registre à chaque changement de traitement (nouveau logiciel, nouveau partenaire, etc.).

e. Plan d'action de mise en conformité

Étape	Action	Délai	Responsable
Court terme	Désigner un DPO, créer le registre des traitements	1 mois	Direction / RH
Moyen terme	Sécuriser les accès, sensibiliser les employés	3 mois	DPO / Informatique

Étape	Action	Délai	Responsable
Long terme	Réaliser un audit RGPD annuel	6-12 mois	DPO / Direction

Conclusion

Mettre en conformité le service RH avec le RGPD est une démarche indispensable pour protéger les données personnelles, renforcer la confiance des salariés et éviter tout risque juridique.

Grâce à la mise en place d'un registre, à la désignation d'un DPO, à la sécurisation des accès et à la suppression des données inutiles, notre entreprise pourra démontrer sa conformité et assurer un traitement responsable et sécurisé des informations de ses collaborateurs.